RGPD vs AI Act : guide comparatif pour formateurs et dirigeants

1. Objectifs respectifs du RGPD et de l'AI Act

1.1. Le RGPD : protéger les données personnelles et les droits individuels

Le Règlement (UE) 2016/679 (RGPD) est le pilier du droit européen de la protection des données. Son objectif principal est de protéger les personnes physiques à l'égard du traitement de leurs données personnelles, tout en garantissant la libre circulation de ces données au sein du marché intérieur.[^1]

Le RGPD est « technologie-neutre » : il s'applique à tout traitement de données personnelles, quel que soit l'outil utilisé (base de données classique, application mobile, algorithme, système d'IA). Il met l'accent sur les droits individuels (information, consentement, accès, rectification, effacement, opposition, portabilité) et sur des principes fondamentaux comme la licéité, la minimisation, la transparence et la sécurité.[2][3][^1]

1.2. L'AI Act : encadrer les risques technologiques des systèmes d'IA

L'AI Act (règlement (UE) 2024/1689) est un règlement sectoriel consacré aux systèmes d'intelligence artificielle. Il ne se limite pas aux données personnelles et vise plus largement à garantir un niveau élevé de protection de la santé, de la sécurité et des droits fondamentaux, y compris la démocratie, l'État de droit et l'environnement.[3][4][^5]

L'AI Act fonctionne comme une réglementation de « sécurité des produits » : il fixe des obligations de conception, de documentation, de gestion des risques et de conformité pour les systèmes d'IA, en particulier ceux à haut risque, plutôt que d'accorder directement de nouveaux droits individuels.[2][3]

2. Principales différences entre RGPD et AI Act

2.1. Champ matériel

- **RGPD** : s'applique à tout traitement de données personnelles, par des moyens automatisés ou non, lorsqu'il existe un fichier structuré ou un traitement automatisé.[1][2]
- **AI Act** : s'applique aux systèmes d'IA (tels que définis à l'article 3 AI Act) mis sur le marché ou utilisés dans l'UE, que ces systèmes traitent ou non des données personnelles.[5][3]

Concrètement, un système d'IA qui ne manipule pas de données personnelles (par exemple un algorithme optimisant l'énergie d'une usine sans données relatives à des personnes) peut être soumis à l'AI Act mais pas au RGPD.[^3]

2.2. Approche du risque

Le RGPD intègre la notion de risque (AIPD, mesures de sécurité proportionnées, traitements de données sensibles), mais impose un socle d'obligations relativement uniforme à tout traitement de données personnelles. L'AI Act adopte au contraire une approche fortement graduée en fonction du risque : systèmes interdits (risque inacceptable), systèmes à haut risque, systèmes à risque limité (transparence) et systèmes à risque minimal.[5][3]

2.3. Droits des personnes vs exigences de conception

Le RGPD crée des droits individuels étendus, dont l'exercice est garanti par les responsables du traitement et les autorités de protection des données. L'AI Act, en dehors de certaines obligations de transparence (par exemple informer lorsqu'une personne interagit avec une IA), se concentre davantage sur les obligations des fournisseurs et des déployeurs de systèmes d'IA (gestion des risques, qualité des données, supervision humaine, documentation).[6][2][1][5]

2.4. Territorialité et acteurs

Les deux textes ont une portée extraterritoriale : ils s'appliquent à des organisations hors UE dès lors qu'elles ciblent le marché européen ou y utilisent des systèmes d'IA. Mais ils ne ciblent pas les mêmes acteurs :[3][1]

- RGPD : responsables de traitement et sous-traitants.[^1]
- AI Act : fournisseurs (providers), déployeurs (deployers), importateurs, distributeurs, et fournisseurs de modèles d'IA à usage général.[6][5]

3. Complémentarités entre RGPD et AI Act

3.1. Deux angles sur les mêmes systèmes d'IA

Dans de nombreux cas, un même système d'IA sera soumis simultanément au RGPD et à l'AI Act : il traite des données personnelles et relève d'une catégorie de risque définie par le règlement sur l'IA.[7][3]

Le RGPD régit alors la dimension « données » (bases légales, droits des personnes, sécurité et minimisation), tandis que l'AI Act régit la dimension « système d'IA » (qualité des données d'entraînement, robustesse, documentation, supervision humaine). L'EDPB rappelle que l'AI Act est « sans préjudice » du RGPD : le respect de l'un n'implique pas automatiquement le respect de l'autre.[8][9][10][2]

3.2. DPIA (AIPD) vs évaluation de conformité / évaluations de risques IA

Le RGPD impose une analyse d'impact relative à la protection des données (DPIA/AIPD) pour les traitements susceptibles d'engendrer un risque élevé pour les droits et libertés. L'AI Act impose, pour les systèmes à haut risque, une gestion des risques et une évaluation de conformité, parfois par des organismes tiers.[5][6][^1]

Ces démarches sont complémentaires : l'AIPD se concentre sur les risques pour la vie privée et les données personnelles, tandis que l'évaluation AI Act couvre aussi les risques systémiques (biais, discrimination, sécurité physique).[11][8]

4. Dans quels cas chaque règlement s'applique ?

4.1. Cas où seul le RGPD s'applique

- Un outil d'analytics simple ou un CRM qui traite des données personnelles, sans fonctionnalité d'IA au sens de l'AI Act (c'est-à-dire sans capacité autonome d'inférence ou de génération).[^3]
- Un traitement manuel de dossiers clients ou de salariés consigné dans un fichier structuré (par exemple un classeur papier indexé par nom).[^1]

Dans ces cas, le RGPD s'applique pleinement, mais l'AI Act n'est pas déclenché.[^3]

4.2. Cas où seul l'AI Act s'applique

- Un système d'IA de maintenance prédictive sur une machine industrielle qui ne collecte que des mesures techniques sans lien avec des personnes.[^3]
- Un modèle d'IA d'optimisation énergétique d'un bâtiment qui ne traite aucune donnée relative à des occupants identifiables.[^3]

Ces systèmes peuvent être soumis aux obligations de l'AI Act (par exemple en tant que systèmes à haut risque si intégrés dans des produits réglementés), sans triggrer le RGPD faute de données personnelles.[12][5]

4.3. Cas où les deux s'appliquent

- Un système de scoring de candidats pour un recrutement, fondé sur des données personnelles et relevant de l'annexe III AI Act (emploi).[12][5]
- Un modèle d'IA générative utilisé pour rédiger automatiquement des réponses à des clients, en se basant sur leur historique d'achats.[6][5]

Dans ces situations, les obligations du RGPD (bases légales, droits individuels, sécurité) et de l'AI Act (classification du risque, gestion des risques, supervision humaine, documentation) doivent être respectées cumulativement.[9][7]

5. Erreurs de compréhension les plus fréquentes

1. « **Si mon IA respecte l'AI Act, je suis forcément conforme au RGPD** » : faux. Le respect des exigences de conception et de risk management de l'AI Act ne garantit pas que les traitements de données personnelles sont licites ou que les droits sont respectés.[10][9]
2. « **Le RGPD ne s'applique pas aux IA tant qu'elles ne collectent pas de données nominatives** » : faux. La notion de données personnelles inclut toute information permettant

d'identifier une personne directement ou indirectement (identifiants techniques, logs, profils).[2][1]

3. « **Le RGPD est dépassé par l'AI Act** » : faux. Le RGPD reste la référence pour tout traitement de données personnelles, y compris dans des systèmes d'IA ; l'AI Act ajoute des exigences structurelles mais ne remplace pas le RGPD.[10][3]
4. « **L'AI Act ne concerne que les grands modèles de base** » : faux. L'AI Act couvre tous les systèmes d'IA au sens de l'article 3, avec des exigences proportionnées au risque (du minimal au haut risque).[13][5]
5. « **Les IA à risque minimal sont totalement hors du droit européen** » : faux. Même si l'AI Act ne prévoit pas d'obligations spécifiques pour ces systèmes, le RGPD s'applique dès qu'il y a des données personnelles et les règles générales du droit restent pertinentes.[1][3]

6. 20 situations professionnelles : RGPD / AI Act / niveau de risque / recommandations

> Les niveaux de risque sont indiqués selon l'AI Act (inacceptable, élevé, limité, minimal) et de manière pédagogique. En pratique, une analyse de cas précise reste nécessaire.

Situation 1 – Utilisation de ChatGPT pour rédiger des emails marketing à partir d'un fichier clients

- RGPD concerné : **Oui** (traitement de données clients).[^1]
- AI Act concerné : **Oui** (IA générative interactive, risque limité).[14][5]
- Niveau de risque : **Risque limité**.
- Recommandations :
  - Informer les équipes et, le cas échéant, les clients de l'usage d'IA pour la rédaction.[^5]
  - Ne pas transférer de données sensibles ou superflues dans les prompts.[^1]
  - Encadrer contractuellement le fournisseur d'IA et vérifier les transferts de données hors UE.

Situation 2 – Chatbot de support client sur un site e-commerce (basé sur Gemini ou Claude)

- RGPD : **Oui** (logs et contenu des conversations peuvent être personnels).[^1]
- AI Act : **Oui** (système d'IA interactif, risque limité).[13][5]
- Risque : **Limité** (potentiellement élevé si décisions essentielles).[^5]
- Recommandations :
  - Afficher clairement que le client interagit avec un chatbot.[^5]
  - Éviter que le chatbot ne prenne seul des décisions sur l'accès à des services essentiels.
  - Documenter l'usage dans le registre RGPD.

Situation 3 – Outil d'IA de tri de CV pour le recrutement

- RGPD : **Oui** (données de candidats).[^1]
- AI Act : **Oui** (Annexe III – emploi). Système potentiellement **haut risque**.[12][5]
- Risque : **Élevé**.
- Recommandations :
  - Réaliser une AIPD RGPD et une analyse de risques AI Act.[11][1]
  - Assurer une supervision humaine effective.
  - Documenter les critères, tester les biais, permettre des explications aux candidats.

Situation 4 – Assistant IA interne pour aider les managers à préparer des évaluations annuelles

- RGPD : **Oui** (données RH).[^1]
- AI Act : **Oui**, mais selon l'usage souvent **risque limité** (outil d'aide).[5][3]
- Risque : **Limité à élevé** si l'IA influence directement les décisions.
- Recommandations :
  - Ne pas laisser l'IA décider seule des promotions ou sanctions.
  - Informer les salariés de l'usage d'outils d'IA dans le processus.
  - Minimiser les données injectées dans le système (pas de données sensibles).

Situation 5 – Scoring automatique de crédit à la consommation basé sur l'IA

- RGPD : **Oui** (données clients).[^1]
- AI Act : **Oui**, cas d'usage typique de **haut risque** (accès à des services essentiels).[6][5]
- Risque : **Élevé**.
- Recommandations :
  - AIPD + évaluation de conformité AI Act.[^11]
  - Supervision humaine, voies de recours, explications des décisions.
  - Gestion fine des biais (non-discrimination).

Situation 6 – Utilisation d'un modèle d'IA pour prévoir le risque de délinquance d'individus

- RGPD : **Oui** (données personnelles sensibles).[^1]
- AI Act : **Oui**, pratique explicitement **interdite** (prédiction du risque d'infractions sur la base du profilage).[^15]
- Risque : **Inacceptable**.
- Recommandations :
  - Ne pas mettre en œuvre ce type de système.

- Chercher des alternatives non fondées sur des profils individuels (statistiques agrégées).

Situation 7 – Social scoring des clients (classement par « fiabilité » pour offrir des avantages)

- RGPD : **Oui**.[^1]
- AI Act : **Oui**, social scoring interdit dans certaines configurations (sanctions disproportionnées ou dans des contextes non liés).[15][5]
- Risque : **Inacceptable à élevé**.
- Recommandations :
  - Éviter les systèmes de scoring global qui affectent de multiples domaines.
  - Privilégier des critères transparents et limités au service concerné.

Situation 8 – Analyse d'émotions des salariés via webcam pendant des réunions

- RGPD : **Oui** (données biométriques).[^1]
- AI Act : **Oui**, pratique de reconnaissance des émotions au travail **interdite**, sauf exceptions médicales/sécurité.[13][15]
- Risque : **Inacceptable**.
- Recommandations :
  - Ne pas déployer ce type de solution.
  - Sensibiliser les managers à l'interdiction liée aux émotions.

Situation 9 – IA d'optimisation énergétique d'un bâtiment (sans données personnelles)

- RGPD : **Non** (pas de données personnelles).[^3]
- AI Act : **Oui**, système d'IA, généralement **risque minimal ou limité**.[5][3]
- Risque : **Minimal**.
- Recommandations :
  - Appliquer les bonnes pratiques techniques (robustesse, sécurité).
  - Créer une documentation allégée sur le système.

Situation 10 – Filtres anti-spam et correcteurs orthographiques dans la messagerie

- RGPD : **Oui** (données dans les emails), mais traitements souvent encadrés par la nécessité et la sécurité.[^1]
- AI Act : **Souvent Non**, si ces outils sont classés comme **risque minimal** et hors champ pratique de l'AI Act.[^3]
- Risque : **Minimal**.

- Recommandations :
  - Vérifier les paramètres de confidentialité.
  - Informer les utilisateurs des filtres appliqués, si nécessaire.

Situation 11 – Système d'IA pour la prévision de la demande de production (données agrégées clients)

- RGPD : **Oui** si les données ne sont pas totalement anonymes.[^1]
- AI Act : **Oui**, mais généralement risque **limité ou minimal**.[5][3]
- Risque : **Limité**.
- Recommandations :
  - Anonymiser au maximum les données.
  - Documenter le modèle et ses limites.

Situation 12 – Outil de recommandation de contenu sur un site média (personnalisation par IA)

- RGPD : **Oui** (profilage de lecteurs).[^1]
- AI Act : **Oui**, mais souvent **risque limité ou minimal** (pas listé en haut risque).[3][5]
- Risque : **Limité**.
- Recommandations :
  - Respecter le RGPD pour le profilage (base légale, droit d'opposition).[^1]
  - Informer sur l'existence de recommandations automatisées.

Situation 13 – IA pour la gestion des ressources humaines (planning, rotations, sans décisions individuelles majeures)

- RGPD : **Oui** (données RH).[^1]
- AI Act : **Oui**, classification dépend du rôle de l'IA dans l'emploi ; souvent **risque limité**, sauf si décisions majeures (recrutement, licenciement).[12][5]
- Risque : **Limité à élevé**.
- Recommandations :
  - Documenter les effets sur les salariés.
  - Assurer une possibilité de correction humaine.

Situation 14 – IA pour la gestion des flux de patients dans un hôpital (sans diagnostics automatisés)

- RGPD : **Oui** (données de santé).[^1]
- AI Act : **Oui**, selon l'intégration potentiellement **haut risque** (infrastructures critiques / santé).[12][5]
- Risque : **Élevé**.
- Recommandations :
  - AIPD et évaluation AI Act.
  - Sécurisation renforcée, supervision médicale.

Situation 15 – Génération automatisée de rapports financiers internes avec une IA

- RGPD : **Oui** si les rapports contiennent des données personnelles (noms, salaires).[^1]
- AI Act : **Oui**, mais en général **risque limité**.[^5]
- Risque : **Limité**.
- Recommandations :
  - Limiter les données personnelles dans les rapports.
  - Contrôler les sorties avant diffusion.

Situation 16 – IA pour la détection de fraude sur les transactions clients

- RGPD : **Oui** (données clients).[^1]
- AI Act : **Oui**, selon la finalité **haut risque** si impact significatif sur l'accès à un service essentiel ou mesures de surveillance.[6][5]
- Risque : **Élevé**.
- Recommandations :
  - Supervision humaine, possibilité de contestation.
  - Documentation des critères et tests de biais.

Situation 17 – Modèle de base (GPAI) intégré dans plusieurs outils internes (assistant de code, rédaction, analyse de texte)

- RGPD : **Oui** si les données interne sont personnelles.[^1]
- AI Act : **Oui**, obligations spécifiques pour les modèles de base.[13][5]
- Risque : **Limité à élevé** selon les usages.
- Recommandations :
  - Vérifier les obligations du fournisseur de modèle de base.
  - Encadrer les usages internes par une charte et des contrôles.

Situation 18 – Système de reconnaissance faciale pour contrôler l'accès à des locaux de l'entreprise

- RGPD : **Oui** (données biométriques).[^1]
- AI Act : **Oui** ; classification dépend du contexte (haut risque, voire interdit si aspiration massive).[15][5]
- Risque : **Élevé à inacceptable**.
- Recommandations :
  - Évaluer des méthodes alternatives (badges).
  - Si utilisé, respecter strictement le cadre légal, limiter le champ d'application et la conservation.

Situation 19 – IA pour générer des contenus de formation interne (textes, quiz) sans données personnelles

- RGPD : **Non** si aucune donnée personnelle n'est utilisée.[^3]
- AI Act : **Oui**, IA générative, risque **limité**.[14][5]
- Risque : **Limité**.
- Recommandations :
  - Documenter le choix d'outils.
  - Vérifier la qualité des contenus et les biais.

Situation 20 – Utilisation de logs d'utilisation d'un SaaS pour améliorer un produit via IA (sans identifiants personnels, données agrégées)

- RGPD : **Potentiellement Non**, si les données sont véritablement anonymes ; **Oui** si pseudonymisées.[3][1]
- AI Act : **Oui**, selon la qualification du système ; souvent **risque minimal ou limité**.[5][3]
- Risque : **Minimal à limité**.
- Recommandations :
  - Privilégier l'anonymisation.
  - Documenter les variables utilisées pour éviter les ré-identifications.

7. Points clés pour les formateurs et dirigeants

1. Le RGPD et l'AI Act ne s'excluent pas mais se complètent : le premier encadre les données personnelles, le second encadre la conception et l'usage des systèmes d'IA en fonction des risques.[7][2]
2. Une même solution (par exemple un assistant RH ou un système de scoring clients) peut être soumise aux deux textes ; la conformité doit être pensée de manière intégrée (gouvernance données + gouvernance IA).[11][3]

3. Le respect de l'AI Act ne suffit jamais à garantir la conformité RGPD ; inversement, un traitement conforme au RGPD peut rester problématique au regard de l'AI Act (par exemple reconnaissance faciale ou social scoring).[16][9]
4. Les organisations doivent cartographier leurs systèmes d'IA, classifier les usages selon les catégories de risque AI Act et identifier où des données personnelles interviennent pour appliquer le RGPD.[7][13]
5. Pour les formateurs, il est utile de présenter le RGPD comme le « droit des personnes et des données » et l'AI Act comme le « droit des systèmes et des risques », afin d'aider les publics à comprendre la complémentarité plutôt que d'opposer les deux textes.[2][3]

References

1. Legal framework of EU data protection - European Commission - Data protection is a fundamental right in the EU. This right is enshrined in Article 8 of the EU Cha...
2. Europe: The EU AI Act's relationship with data protection law - The EU AI Act and the GDPR are designed to work hand-in-glove, with the latter 'filing the gap' in t...
3. GDPR and AI Act: similarities and differences | activeMind.legal - The GDPR and the AI Act have many basic principles in common, such as transparency and accountabilit...
4. EU Artificial Intelligence Act | Up-to-date developments and ... - The AI Act is a European regulation on artificial intelligence (AI) – the first comprehensive regula...
5. AI Act | Shaping Europe's digital future - European Union - The guidelines on prohibited AI practices under the AI Act, which offer legal explanations and pract...
6. Navigating the AI Act | Shaping Europe's digital future - These questions and answers detail the AI Act's goals, governance, enforcement and clarify provision...
7. The AI Act & GDPR: A Guide to EU Compliance for Businesses - Learn how to navigate the AI Act & GDPR for EU compliance. Practical tips for AI risk management and...
8. [PDF] artificial-intelligence-systems-and-the-gdpr---a-data-protection ... - GDPR and AI Act alignment: the brochure highlights the complementary nature of the GDPR and AI Act i...
9. [PDF] Data Protection and AI Act The European Data Protection Board ... - What's next? 1. Guidelines on the Interplay between the AI Act and the GDPR in close cooperation wit...
10. EDPB opinion on AI models: GDPR principles support responsible AI - The EDPB wants to support responsible AI innovation by ensuring personal data are protected and in f...
11. Interactions and overlaps between the GDPR and AI Act, with ... - Harmonising the AI Act with the GDPR presents several challenges, as both aim to safeguard individua...
12. Article 6: Classification Rules for High-Risk AI Systems - EU AI Act - AI systems of the types listed in Annex III are always considered high-risk, unless they don't pose ...
13. Frequently Asked Questions - AI Act Service Desk - European Union - This list of FAQs has been compiled based on queries received during the AI Pact webinars as well as...
14. 8 questions and answers about the AI Act - Wired Relations - Do you have doubts about the AI Act? Get answers to 8 key questions and learn how you can adapt yo...

15. Article 5: Prohibited AI Practices | EU Artificial Intelligence Act - The following AI practices shall be prohibited: (a) the placing on the market, the putting into serv...
16. How the EU AI Act Supplements GDPR in the Protection of Personal ... - In all cases, AI systems involving the processing of personal data must meet the GDPR requirements. ...